React2Shell Security Bulletin

CVE-2025-55182 is a critical vulnerability in React, Next.js, and other frameworks that requires immediate action

Security Team

Copy URL Copy page Ask AI about this page

6 min read Last updated December 26, 2025

December 11, 2025 update: Following the React2Shell disclosure, increased community research into React Server Components surfaced two additional vulnerabilities that require patching: CVE-2025-55184 (DoS) and CVE-2025-55183 (source code disclosure). See the new Security Bulletin for details.

On December 4, 2025, publicly available exploits emerged for React2Shell, a critical vulnerability in React Server Components affecting React 19 (CVE-2025-55182) and frameworks that use it like Next.js (CVE-2025-66478). The situation continues to be dynamic. We recommend checking this page and the Vercel Developers X Account frequently for the latest updates, and will continue to include them in the Vercel Dashboard as well.

Required action

The vulnerability affects Next.js versions 15.0.0 through 16.0.6. If you're running an affected version, upgrade immediately, regardless of other protections in place. Jump to the How to upgrade and protect your Next.js app guide to learn how to patch and protect your application.

Updates

Date	Update
December 08, 8:31 PM PST	Vercel Agent can perform automated code reviews and open pull requests to upgrade vulnerable projects. See the automated upgrade section for details.
December 08, 6:09 PM PST	We strongly recommend turning on Standard Protection for all of your deployments (besides your production domain) and auditing shareable links from all deployments. See the deployment protection section of the bulletin for instructions.
December 06, 9:05 PM PST	If your application was online and unpatched as of December 4th, 2025 at 1:00 PM PT, we strongly encourage you to rotate any secrets it uses, starting with your most critical ones. Information on patching secrets can be found in our docs.
December 05, 10:29 PM PST	Vercel has released an `npm` package to update your affected Next.js app. Use `npx fix-react2shell-next` or visit the GitHub page to learn more
December 05, 3:44 PM PST	Vercel has partnered with HackerOne for responsible disclosure of critical Vercel Platform Protection workarounds. Valid reports that demonstrate a successful bypass of Vercel protections will be rewarded for this CVE only. Bounties are **$25,000 for high** and **$50,000 for critical.** Visit the HackerOne page to participate.

In this bulletin:

- When to upgrade your application
- Understand what React2Shell is and if it affects you
- How to upgrade and protect your Next.js app
  - Vercel security actions dashboard
  - Vercel deployment protection
  - Version upgrade methods
  - Rotating environment variables
- How to upgrade other frameworks
- Frequently asked questions

When to upgrade your application

You should upgrade if:

- **You're using Next.js 15.0.0 through 16.0.6**: All Next.js applications running versions between 15.0.0 and 16.0.6 are affected by this vulnerability.
- **You're using Next.js 14 canary versions:** If you're using Next.js 14 canaries after 14.3.0-canary.76, you are also vulnerable and need to downgrade or upgrade.
- **You're using React Server Components in any framework:** This vulnerability affects React Server Components broadly. If you use RSC through Next.js or another framework, you need to update.

Recommendation

For Next.js, upgrading to a patched version is strongly recommended and the only complete fix. All users of React Server Components, whether through Next.js or any other framework, should update immediately. Learn how to upgrade for Next.js and other frameworks.

Understanding React2Shell

React2Shell is a critical vulnerability in React Server Components that affects React 19 and frameworks that use it. Under certain conditions, specially crafted requests could lead to unintended remote code execution.

Checking your vulnerability status

The most reliable way to determine if you're vulnerable is to check your deployed version of React and Next.js. You need to verify the versions of:

- `next`
- `react-server-dom-webpack`
- `react-server-dom-parcel`
- `react-server-dom-turbopack`

If you're using Vercel, you will see a banner in the vercel.com dashboard when your production deployment is using a vulnerable version of these packages. This banner is an additional indication to review your deployment.

Everyone should also check their versions directly. This can be done automatically by using `npx fix-react2shell-next` (see instructions in this section of the bulletin).

Vercel WAF protection

Vercel WAF rules provide an additional layer of defense by filtering known exploit patterns:

- Prior to the CVE announcement, Vercel worked with the React Team to design WAF rules to block exploitation and globally delivered protection to all Vercel users.
- Ongoing monitoring for new exploit variants with iterative WAF rule updates (as of December 5, 2025, additional rules were deployed to cover newly identified attack patterns)

WAF rules cannot guarantee protection against all possible variants of an attack.

How to upgrade and protect your Next.js app

In this section:

- Vercel security actions dashboard
- Vercel deployment protection
- Version upgrade methods
  - Automated upgrade with Vercel Agent
  - Upgrade with the command line utility
  - Manual upgrade
- Rotating environment variables

Vercel security actions dashboard

Vercel provides a unified dashboard that surfaces any security issues requiring action from your team, including remediation steps. View your security actions dashboard.

Vercel deployment protection

Even if your production app has been patched, older versions could still be vulnerable. We strongly recommend turning on Standard Protection for all deployments besides your production domain.

You can see a list of projects without deployment protection in your security actions dashboard or by reviewing your deployment protection settings.

Make sure that preview deployments and deployments from other environments are not used by external users without protection bypass first (see the documentation for details).

You should also audit shareable links from your deployments. If you have disabled deployment protection to share domains that point to preview or custom environment deployments, you should implement deployment protection exceptions and make sure that all deployments added to the exception list have been patched.

Version upgrade methods

Automated upgrade with Vercel Agent

Vercel Agent can automatically detect vulnerable projects and open PRs that upgrade your code to patched versions.

View vulnerable projects and initiate upgrades in the Vercel dashboard.

Upgrade with the command line utility

You can quickly update your Next.js project to the right version by using the `fix-react2shell-next` npm package by running the following command in the root of your application:

>_ terminal

```
npx fix-react2shell-next
```

Once tested, deploy your updated application as soon as possible. See the deployment guide for instructions.

Manual upgrade

1. Identify your current version

Load a page from your app and run `next.version` in the browser console to see the current version or check your `package.json` to find your current Next.js version:

package.json

```
{
  "dependencies": {
    "next": "15.3.4"
  }
}
```

2. Update to the patched version

Based on the following list, identify which patched release you need to upgrade to:

Vulnerable version	Patched release
Next.js 15.0.x	15.0.5
Next.js 15.1.x	15.1.9
Next.js 15.2.x	15.2.6
Next.js 15.3.x	15.3.6
Next.js 15.4.x	15.4.8
Next.js 15.5.x	15.5.7
Next.js 16.0.x	16.0.10
Next.js 14 canaries **after** 14.3.0-canary.76	Downgrade to 14.3.0-canary.76 (not vulnerable)
Next.js 15 canaries **before** 15.6.0-canary.58	15.6.0-canary.58
Next.js 16 canaries **before** 16.1.0-canary.12	16.1.0-canary.12 and after

These patched versions include the hardened React Server Components implementation.

If you're currently using canary releases to enable PPR, you can update to 15.6.0-canary.58, which includes a fix for the vulnerability while continuing to support PPR. For other ways to patch older versions, see this discussion post.

Update your `package.json`:

package.json

```
{
  "dependencies": {
    "next": "15.3.6"
  }
}
```

3 . Install dependencies and update lockfile

Always commit lockfile changes with together with `package.json` *changes.*

Run your package manager's install command:

terminal

```
# npm
npm install

# yarn
yarn install

# pnpm
pnpm install

# bun
bun install
```

4. Deploy immediately

Once tested, deploy your updated application as soon as possible. See the deployment guide for instructions.

Deployment guide

Once tested, deploy your updated application as soon as possible.

If you're deploying to Vercel, the platform already blocks new deployments of vulnerable versions and has WAF rules in place, but upgrading remains critical.

If you deploy via Git, pushing your changes will trigger a preview build with the patched version, and merging will promote that build to production. You can also create a Manual Deployment from the Vercel Dashboard to publish the fix immediately.

If you are using the Vercel CLI, deploy with:

>_ terminal

```
vercel --prod
```

Rotating environment variables

Assume your vulnerable systems are potentially compromised. Once you have patched your framework version and re-deployed your application, we recommend rotating all your application secrets. Learn how to rotate the environment variables for your Vercel team and projects.

How to upgrade other frameworks

If you use another framework that implements React Server Components, consult the React Security Advisory posted on the react.dev blog. If you are running a vulnerable version of the affected software, you should update to a patched version immediately.

Next steps

- Review the official Next.js security advisory
- For additional questions, contact us at security@vercel.com.

Frequently asked questions

What's the easiest way to upgrade to a patched version? >

How do I know if I'm vulnerable to this CVE? >

How do I know if my app was exploited by CVE-2025-66478? >

What are the protections available to me? >

What if I am using canary-only features in Next.js? >

How can I test that the mitigations are working? Should I be using publicly available POCs to test if my application is secure? >

Are v0 applications vulnerable? >

Was this helpful?

Sandbox NEW
Startups
Solution partners
Academy
Community

FRAMEWORKS
Next.js
Nuxt
Svelte
Nitro
Turbo

SDKS
AI SDK
Workflow SDK NEW
Flags SDK
Chat SDK
Streamdown AI NEW

USE CASES
Composable commerce
Multi-tenant platforms
Web apps
Marketing sites
Platform engineers
Design engineers

COMPANY
About
Careers
Help
Press
Legal
Privacy Policy

COMMUNITY
Open source program
Events
Shipped on Vercel
GitHub
LinkedIn
X
YouTube

LOADING STATUS…